SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct: (192472250)

I M. Chandana *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

Question : 1

Exploiting A Vulnerability without clearly Defined Scope

→ As an ethical hacker, I would not exploit the critical vulnerability immediately because the company has provided only a one-line email authorization without clearly defining the testing scope.

* Even though, discovered a serious vulnerability exploiting a system that is not included in the approved scope could cause unexpected damage and created legal psoblems.

the main ethical hacking psinciples involved are :

Authorized : obtain explait permission before testing systems

Defined Scope: Test only the systems and activities approved by the clients.

Non-maleficence : Avoid causing harm to system data or users.

Confidentiality : psotect all information discovered dusing the testing.

Conclusion :

The goal of penetration testing is to improve security not to compromise Customers privacy the vulnerability should be verified using the least of intrusive method possible, with proper authorized and safe guards.

Question : 3

Accidental Denial - of - a Service on a live of production Server

During a black - box penetration test, accidentally triggering a denial - of - Service (DOS) Condition on a live production Server can interrupt business operation and effect the Customers.

Steps that Should have been taken to prevent the Incident

→ Review the rules of engagement and identify prohibited high - impact tests.

→ Obtain explicts approvals before conductivity Stress load or denial - of - Service testing

→ When a use a staging environment or isolated test System whenever possible.

→ Apply Conservative testing rate, monitor servers performance and establish stop conditions.

→ Ensure that recovery and backup procedures

Responsibilities after the Incident:

→ Immediately Stop the test activity that Caused the outage.

→ Notify the clients designated emergency Contact and incident-response team.

→ Cooperate with authorized personnel to restore the service safely.

→ preserve relewant logs and document the timeline action taken and observed affects.

Conclusion:

Ethical hacker must prioize availability to minimize harm, and respond honestly to incidents. Responsible reporting and immediate action are to essential for restoring trust and preventing similar fiures

Question: 4

Testing Systems without informing the IT Department

A client may request a covert security test to evaluate whether the IT department can detect real-world attacks. This type of exercise can be useful. But testing without informing the IT team creates ethical operations.

For Example: A bank may want to test whether its security team detects suspicious login attempts or unauthorized access attempts if the IT department is unaware of the exercise, it might that the activity as a genuine attack.

Ethical And practical Risks:

Legal Risks: the test may exceed the clients authority or violate applicable laws.

Operational Risks: Testing may disrupt important services or affect customers.

Misunderstanding: Security staff may mistake the test for a real criminal attack.

How I would Structure the Engagement-

→ Obtain, written authorization from a appropriate of senior authority who has the power to approve the exercises.

→ Define the objectives, scope, permitted techniques, dusation and prohibited activities.

→ Use a designated controlles or trusted coordination who can intervene if the exercise causes by them.

Conclusion:

A Covert test Can Evaluate real-world detection Capabilities but Secrety must rover replace authorization clear rules of engagement and emergency Contsols psotect both the Osganization and the ethical hackes.

Question : 5

Red team Exercise Vs Vulnerability Assesment- in a bank

A red team exercise and vulnerability assessment are both Secusity-testing methods, but they have different objectivies and Appsoaches. A vulnerabilities assessment identifies Secusity weakness whereas a Red team Exercise Evaluates wheather an Osganization Can detect respond to.

Vulnesability assessment : the psimasy objective is to identify and a document weakness in the banks Systems.

Appsoach :

→ Scan approved Servers, application and network devices fos known vulnesabilities.

→ Check autdated Software, mis Configuration, weak, passwosds and missing Secusity patches.

Ethical Consideration:

* Obtain written authorization
* Avoid disrupting banking services or accessing a unnecessary customers data.
* Report all findings accurately.

Red team Exercise:

The primary objective is to simulate realistic adversesial behaviours and evaluate the banks cover all security defenses including detection and incident response.

Approach:

* Define a realistic objective, such a determining whether an attackes could reach a protected to internal system
* Simulate approved Social- Engineering or physical security scenarios.

Ethical Consideration:

Obtain explicit authorization for digital, physical and Social- Engineering activities.

Conclusion: A vulnerability assessment- helps the bank discoves and fix weakness, while a red team exercise and technology defend against realistic attack.